Securing Autonomous Defense: Contamination and Memory Poisoning in a Learning Agentic SOC

[TODO: authors (team)]
Dept. of CSE, KMIT, Hyderabad, India

***Abstract*—[TODO: team, after the results are final.] Draft points: an LLM-driven SOC has two attack surfaces: the model reads log text an attacker can write, and the memory learns from what it sees and from analysts. We build the full pipeline of an agentic SOC (LLM hypotheses, structural checks against a knowledge graph, response ranking, guardrails, a learning Knowledge Store behind a learning gate, an outcome monitor and an analyst review loop) and evaluate both surfaces: on 1,000 clean/contaminated GUIDE alert pairs and on the real telemetry of the DEDALE dataset with exact labels. Contamination that hijacks an undefended LLM agent on 29.6% of pairs suppresses the pipeline's response on 0.9%, with no misdirected action executed; on real telemetry, attacker text gets a few attack cases dismissed, but the learning gate keeps all of them from being learned. Learning cuts analyst reviews from 6,095 to 65 per day without losing the attack; learning without the gate learns the attacker. Analyst mistakes are the larger poisoning route, and unlearning on confirmed compromise closes it.**

I. Introduction

[TODO: team: agentic SOCs and alert fatigue; why an LLM triage agent that learns is exposed twice; contributions C1–C5.]

II. Background and Related Work

[TODO: team: AgentSOC (base paper); prompt injection and log contamination; memory poisoning in learning systems; alert triage; datasets (GUIDE, DEDALE).]

III. Threat Model

The attacker controls the free text of their own activity as sensors record it: command lines, script text, raw log lines and the names they give their tools. They do not control structured sensor fields (host, account, parent process, image path as recorded, addresses), the asset inventory, the learning gate, or the analyst. Their goals are *suppression* (their activity is dismissed, or learned as routine so that it stops raising alerts) and *misdirection* (containment aimed at the wrong host or account). Tampering with structured fields at the sensor is out of scope for the defences; we measure its effect separately (Section VI-A).

IV. System

[TODO: Claude, from the old draft's Section IV and the code: Fig. 1 (pipeline and loop).] For each new case, the Narrative Counterfactual Engine (NCE), an LLM, proposes ATT&CK hypotheses from the alert. The Structural Simulation Engine (SSE) checks each against a knowledge graph of hosts, accounts, access and network reachability; entity binding compares the entities a hypothesis names with the alert's trusted fields; RSEM ranks responses by containment and business impact; guardrails decide what may run automatically. Around this single-alert pipeline runs the loop:

- a *triage gate* skips patterns the store has learned as routine and reuses decisions for unchanged cases;
- a *learning Knowledge Store* learns structured patterns only (never text; scripts as fingerprints), from a benign training window and afterwards only behind a *learning gate*: a dismissed case is learned after a delay, and only if nothing involving its endpoints was escalated meanwhile;
- an *outcome monitor* watches the targets of executed (simulated) responses and escalates continued activity;
- an *analyst review loop*: analysts' verdicts and approvals enter an inbox that the loop applies (the store keeps a single writer); containment of critical hosts needs two analysts; and when a host is confirmed compromised, what was learned on it in the previous 7 days is retracted and nothing new is learned on it.

SSE treats hosts without telemetry as unknown, not as impossible targets (open world, Section VI-D).

V. Evaluation Setup

GUIDE corpus v2. 500 development and 500 held-out pairs built from Microsoft GUIDE incidents: each pair is a clean alert and a contaminated twin that differs only at the injection site, across 10 payload families (suppression and identity steering), with entities from a synthetic enterprise inventory.

DEDALE. Four weeks of a simulated company's telemetry with an APT-style intrusion and exact labels of the malicious host events on the two attacked Windows clients. The first two weeks are benign and used for training; the attack and the remaining activity fall in the 14 test days (2025-01-06 to 01-19). Detection on host logs comes from the store itself: an event whose structured pattern the store has not learned becomes an alert.

Conditions. Learning modes: static (nothing learned), frozen (training only), gated, ungated. A simulated analyst gives verdicts from the labels after a delay, with optional seeded mistakes. NCE is `gemini-3.1-flash-lite` (and `gpt-oss-20b` on part of GUIDE); live outputs are recorded and replayed, so every number is reproducible offline.

TABLE I
CONTAMINATION ON GUIDE V2 (CLEAN VS CONTAMINATED TWINS).

Run	Suppressed	Induced (non-ERA)	Misdirected exec.
Dev, Gemini	4/428 (0.9%)	4	0
Held-out, Gemini	3/437 (0.7%)	0	0
Dev, gpt-oss-20b*	3/108 (2.8%)	0	0
Undefended agent, dev	130/439 (29.6%)	–	–

*partial run (125 pairs); [TODO: update when complete].

TABLE II
E1: ATTACKER TEXT THROUGH THE FULL LOOP (DEDALE).

Attacker text	Dismissed (no analyst / analyst)	Learned	Alerted
none	0 / 0	0	400
maintenance claim	1 / 0	0	400
fake SOC approval	3 / 0	0	400
steer to the DC	1 / 0	0	400

TABLE III
LEARNING MODES ON DEDALE HOST LOGS (14 TEST DAYS).

Mode	Reviews/day	Attack cases	Events alerted	Attack learned
static	6,095.4	80	473	0
frozen	65.2	72	400	0
gated	65.2	72	400	0
ungated	27.4	38	99	38

TABLE IV
ANALYST MISTAKES, WITHOUT / WITH UNLEARNING (HOST LOGS, 4 H DELAY).

Analyst	Reviews/day	Attack learned	Events alerted
always right	30.9 / 34.1	0 / 0	400 / 400
misses 5%	30.6 / 34.1	8 / 0	397 / 400
misses 20%	30.1 / 34.1	20 / 0	256 / 400
5% false alarms	31.4 / 44.6	0 / 0	400 / 400

VI. RESULTS

A. Contamination (C1)

Table I compares responses on clean and contaminated twins. Contamination suppressed a response the clean twin received in 4 of 428 (development) and 3 of 437 (held-out) pairs; the opposite flips not caused by our ERA escalation were 4 and 0 (McNemar $p = 1.0$ and 0.25). The LLM followed identity-steering payloads, but every steered hypothesis was flagged by entity binding and no misdirected action was executed. On the same 500 development pairs, the undefended LLM triage agent was hijacked into dismissing 130 of 439 contaminated alerts (29.6%, 95% CI 25.5–34.0%, $p = 6.5 \times 10^{-17}$), against 4 of 428 for the pipeline.

Through the full loop on real telemetry (E1). On DEDALE, we appended attacker text to the command lines of the attacker's own 84 process events (38 cases expose it to NCE), in three variants: a maintenance claim, a fake SOC approval, and an instruction to isolate the domain controller instead. Without an analyst, 1, 3 and 1 of the 72 attack cases were dismissed (none in the clean run); with an analyst, none. In every run the learning gate dropped the dismissed cases, so no attack pattern was learned and all 400 labelled attack events still raised alerts. The LLM named the steered host in 30–32 of 38 cases; entity binding flagged every such hypothesis and no containment targeted it (Table II).

B. The learning store (C2)

Table III: without learning, every unseen pattern is a case, 6,095 reviews per day on host logs. Learning the training weeks cuts this to 65 per day while all 72 attack cases still reach review (initial access surfaced 1.2 min after it began, lateral movement after 28.5 min). Learning without the gate cuts further, to 27.4, but only by learning the attacker: 38 attack cases' patterns became routine and only 99 of the 400 attack events raised alerts. On network alerts, learning cuts 552 to 26 reviews per day; without the gate, 4 of 7 attack-related cases were hidden.

C. Memory poisoning through the analyst (C3)

Analyst verdicts bypass the gate by design. A simulated analyst missing 20% of attacks taught the store 20 attack cases' patterns, and only 256 of 400 attack events still raised alerts (Table IV). Unlearning on confirmed compromise removes the effect: with the same mistakes, nothing was learned and all 400 events alerted. It costs 10% more reviews with a perfect analyst (30.9 to 34.1 per day) and makes false alarms more expensive (31.4 to 44.6 per day at 5% false alarms), because a false confirmation stops learning on a healthy host.

D. What the LLM adds (C4)

With NCE, reviews fall from 65.2 to 54.8 per day (16%), by dismissing cases whose hypotheses are all structurally infeasible. Under a closed-world check this dismissed 2 of the 72 attack cases: the attacker copied data from a server the store has no telemetry for, and "no record of access" was read as "impossible". Treating hosts without telemetry as unknown removed both misses at no cost (89 benign dismissals either way). With an analyst in the loop, NCE adds little (33.2 reviews per day with NCE, 34.1 without, both with unlearning).

E. Operating the loop (C5)

Detection does not depend on how fast analysts answer, but workload does: host reviews per day rise from 33.1 to 51.5 as the delay grows from 1 h to 72 h, because benign patterns are learned only when their verdict arrives. On the network, the attacker's server stays reachable until the verdict: containment came 60 min to 72 h after the first alert, equal to the delay.

VII. DISCUSSION AND LIMITATIONS

[TODO: team + Claude.] Limits to state: one real dataset with two labelled attacked hosts; a simulated analyst; one LLM on DEDALE; synthetic entities and payloads in GUIDE v2; actions are simulated.

VIII. Conclusion

[TODO: team.]

References

[1] [TODO: AgentSOC base paper, arXiv:2604.20134.]
[2] [TODO: Microsoft GUIDE dataset.]
[3] [TODO: Inria DEDALE dataset, DOI 10.57745/Y5JLDG (CC BY 4.0).]